



DATA PRIVACY AND SECURITY INCIDENT MANAGEMENT POLICY

Clyptus Software Solutions Pvt. Ltd.

Policy Effective Date: 02/01/2026

Document Owner: Information Technology Department

Contact: privacy@clyptus.com | it.security@clyptus.com | +91 88854 33774

Version: 1.1 (Updated Feb 2026)

Version	Change Description	Prepared By	Reviewed By	Approved By	Date
1.0	Initial issue for Clyptus	Mahitha C	Keerthi Priya	Management	01/01/2024
1.1	Annual review;match global client expectations updated effective date	Mahitha C	Keerthi Priya	Management	02/01/2026

Proprietary Notice: This document is proprietary to Clyptus Software Solutions Pvt. Ltd. ("Clyptus") and is intended for internal use only. Unauthorized copying, reproduction, or disclosure is strictly prohibited.

1. PURPOSE OF THE POLICY

This policy defines Clyptus's commitment to the protection and lawful handling of personal data, outlining the procedures for ensuring compliance with applicable data protection laws such as the Digital Personal Data Protection Act (DPDPA) 2023 and global privacy requirements. It also establishes a structured approach for recording, investigating, and mitigating security incidents involving personal or confidential information.

2. SCOPE AND APPLICABILITY

This policy applies to:

- All employees, contractors, interns, and third-party partners of Clyptus.
- All data processed by or on behalf of Clyptus, including client, employee, and subcontractor information.
- All Clyptus-owned or client-owned IT infrastructure, systems, and devices where company data is processed or stored.

3. PERSONAL DATA ELEMENTS COLLECTED

Clyptus may collect the following personal data during its business operations:

- Identification Information: Name, date of birth, contact numbers, email ID, employee ID.
- Employment Data: Resume, skills, manager/approver name, joining details, timesheets, attendance records.
- Compliance Data: Government-issued IDs, background verification details, affidavit if applicable.
- Biometric/Visual Data: Profile photographs or webcam snapshots for access and identification systems.
- System Information: Login timestamps, device identifiers, and network logs solely for security and audit purposes.

Abbreviation	Full Form
DPDPA	Digital Personal Data Protection Act
HR	Human Resources
ISG	Information Security Group
IT	Information Technology
DPIA	Data Protection Impact Assessment
DPO	Data Protection Officer
ROPA	Records of Processing Activities

TOSM	Technical and Organizational Security Measures
RBAC	Role- Based Access Control
VAPT	Vulnerability Assessment and Penetration Testing
MFA	Multi- Factor Authentication
IDS/IPS	Intrusion Detection System / Intrusion Prevention System
SAST	Static Application Security Testing
DAST	Dynamic Application Security Testing
SIEM	Security Information and Event Management
SLA	Service Level Agreement
RoT	Record of Transfer (Vendor Records of Transfer)

4. LAWFUL BASIS AND PURPOSE OF PROCESSING

Clyptus processes data for legitimate and contractual business purposes, including recruitment, onboarding, payroll, compliance, and security monitoring. No personal data shall be used for any secondary purpose without prior notice or consent, unless required by law.

5. DATA SHARING AND DISCLOSURES

Access to personal data is restricted to authorized internal personnel (HR, IT, Compliance, Finance) and trusted third parties who process data under confidentiality and data protection obligations.

6. CROSS-BORDER DATA TRANSFER

If personal data must be transferred outside India for business or client requirements, such transfers will comply with applicable data protection regulations and standard contractual clauses.

6A. INDIA-SPECIFIC DATA PRIVACY OBLIGATIONS (DPDPA 2023)

Clyptus ensures full compliance with India's Digital Personal Data Protection Act (DPDPA) 2023, including:

- Processing personal data only for lawful purposes with clear notice and consent.
- Implementing organizational and technical controls consistent with DPDPA 'Data Fiduciary' obligations.
- Establishing mechanisms to honor Data Principal rights (Access, Correction, Deletion, Grievance redressal).

- Maintaining Data Protection Impact Assessments (DPIAs) for high-risk data.
- Appointing a Data Protection Officer (DPO) for DPDPA governance.

7. DATA STORAGE AND RETENTION

All personal data shall be stored securely on Clyptus-controlled servers or approved cloud infrastructure backed by strict SLA's. Retention for HR and operational records is 8 years post-employment or as required by legal obligations.

8. DATA SECURITY

Clyptus adopts industry-standard security measures including restricted role-based access control, encryption of data in transit and at rest, secure password policies, and regular vulnerability assessments.

8A. VENDOR & PROCESSOR OBLIGATIONS

Clyptus ensures all third-party processors:

- Process personal data only under documented instructions.
- Report any personal data breach immediately to the Clyptus ISG.
- Maintain adequate Technical and Organizational Security Measures (TOSMs) including encryption and access controls.
- Allow audits by Clyptus to demonstrate compliance.

9. DATA SUBJECT RIGHTS

Individuals may request access, correction, or deletion of their data, or withdraw consent where applicable by contacting privacy@clyptus.com.

10. SECURITY INCIDENT DEFINITION AND CLASSIFICATION

A security incident is any event that results in unauthorized access, loss, or destruction of data. Incidents are classified as Low, Medium, or High severity based on sensitivity and impact.

10A. PERSONAL DATA BREACH OBLIGATION

In case of a breach involving personal data, Clyptus will conduct immediate investigation. Clyptus shall notify affected individuals and the Data Protection Board of India where required. Breach logs must be maintained for 8 years.

11. SECURITY INCIDENT REPORTING AND RESPONSE

All personnel must report suspected incidents within 2 hours to the Immediate Manager and ISG (it.security@clyptus.com). Response involves: Reporting → Recording → Containment → Investigation → Mitigation → Notification → Closure.

12. ROLES AND RESPONSIBILITIES

- Data Privacy Officer (DPO): Oversee compliance and coordinate disclosures.
- Information Security Group (ISG): Manage security controls and incident response.

- HR Department: Ensure employee awareness.
- Employees/Subcontractors: Follow security practices and report incidents.

13. DISCIPLINARY CONSEQUENCES

Failure to comply or willful concealment of incidents may result in disciplinary action up to and including termination and legal proceedings as enumerated in the disciplinary policy.

14. POLICY REVIEW AND UPDATES

This policy will be reviewed annually or upon significant regulatory, business, or security changes.

14A. ADDITIONAL RECORD-KEEPING & ACCOUNTABILITY

Clyptus will maintain Records of Processing Activities (ROPA), data classification inventories, consent logs, and training records.

14B. DOCUMENT VERSION APPROVAL

Prepared By	Reviewed By	Approved By
 Mahitha C/ HR /02.01.2026	 Mahima Jaiswal/ HR Head/ /02.01.2026	 Keerthi Priya/Director/ /02.01.2026
Name / Designation / Date	Name / Designation / Date	Name / Designation / Date

ACKNOWLEDGEMENT

☐ I have read, understood, and agree to comply with the Clyptus Data Privacy and Security Incident Management Policy.

☐ I understand that non-compliance may result in disciplinary or legal action taken by Clyptus Software Solutions Pvt. Ltd.

Signature: _____

Full Name: _____

Date: _____

Designation: _____

Employee ID: _____

Annexure A - Security Incident Record Form

Section	Details
Incident ID	
Date & Time	
Reported By	
Type of Incident	☐ Data Breach ☐ Malware ☐ Unauthorized Access ☐ Policy Violation
Description	
Severity	☐ Low ☐ Medium ☐ High
Action Taken	
Closure Date	



IT SECURITY & PRIVACY ASSESSMENT REPORT

Clyptus Software Solutions Pvt. Ltd.

Assessment Periods:

- FY 2024–2025
- FY 2025–2026 (ongoing)

1. Executive Summary

Clyptus has undergone a comprehensive Information Security & Privacy Audit covering governance, technical controls, operational discipline, and DPDPA readiness. Overall maturity aligns with Moderate to High security standards, with specific gaps identified in vendor management, incident logging consistency, and breach classification workflows.

2. Assessment Areas

- Data Protection & DPDPA Compliance
- Access Governance & Identity Management
- Cloud & Infrastructure Security
- Incident Response Maturity
- Vendor Risk Management
- Application Security
- Endpoint Security & Patch Management
- Backup & Disaster Recovery
- Policy Documentation & Employee Awareness

3. Assessment Findings (FY 2024–25)

Strengths

- Strong encryption practices across transit and rest.
- Role-based access control with periodic access reviews.
- Annual VAPT completed with medium- level findings remediated.
- Adoption of Microsoft Azure security best practices (per clyptus.com technology stack).
- HR and ISG collaboration functional for incident management.

Gaps Identified

- Inconsistent breach severity classification across departments.
- Lack of centralized incident response tooling (manual spreadsheets used).
- No formal DPIA framework for high- risk projects involving biometric or client datasets.

- Vendor contracts lack specific DPDPA clauses (updated in FY 24- 25 Q4).
- Patch management delays for non- Windows assets (Linux servers were 15–45 days behind baseline).

Risk Level

Medium

4. Assessment Findings (FY 2025–26 – YTD)

Improvements

- Implementation of centralized Incident Tracker (ISG- Ops Suite).
- Introduction of DPIA process for client onboarding.
- Updated Privacy Policy aligned with DPDPA (Jan 2026 release).
- Third- party vendor due- diligence checklist implemented.

Outstanding Gaps

- Incident reporting timelines not consistently followed (expectation: within 2 hours).
- Lack of automated anomalous login detection.
- No cross- border transfer assessment framework (required under DPDPA).

Risk Level

Medium–Low (improving trajectory)

5. Technical Control Evaluation

Identity & Access Management

Status: Strong

- Multi- factor authentication mandatory for employees and contractors.
- Privilege elevation approvals logged but not fully automated.

Network Security

Status: Moderate

- Firewalls configured with segmentation.
- Need enhanced IDS/IPS monitoring.

Data Encryption

Status: Strong

- AES- 256 at rest, TLS 1.2+ in transit.

Logging & Monitoring

Status: Moderate

- SIEM integrated for core servers.
- Endpoint logging coverage at ~72% (target: 95%).

Application Security

Status: Developing

- Secure coding guidelines available but not uniformly adopted.
- SAST/DAST partially implemented.

6. Compliance Evaluation

DPDPA 2023

Status: Partial Compliance

Missing elements:

- Consent management maturity
- Cross-border controls
- Data retention validation audits

Client Contractual Obligations

Status: Considerable Compliance

- SLA adherence high.
- Need enhanced evidence collection for audits.

7. Recommendations

High Priority

- Automate breach severity classification and logging.

- Establish cross-border transfer assessment framework.
- Implement full SAST/DAST integration in CI/CD.
- Expand endpoint logging coverage.

Medium Priority

- Strengthen vendor privacy assurance and annual audits.
- Expand data discovery and classification tooling.
- Implement insider threat detection analytics.

Low Priority

- Quarterly privacy awareness sessions (currently annual).
- Documentation clean-up for ROPA, DPIAs, and vendor RoTs.

8. Overall Maturity Score (Clyptus Internal Model)

- People: 3/5
- Process: 3.5/5
- Technology: 4/5
- Compliance: 3/5
- Overall Score: 3.4/5 (Moderately Mature Security Posture)

9. Conclusion

Clyptus maintains a strong baseline security posture with continued improvement. To achieve full DPDPA alignment and match global client expectations, the organization should prioritize automation, vendor governance, and privacy-by-design practices during FY 2026.

Annexure A - IT Security & Privacy Assessment Report (FY 2024-26)

Assessment Periods: FY 2024–2025 & FY 2025–2026 (Ongoing)

Summary Findings

Category	FY 2024-25 Status	FY 2025-26 Improvements
Strengths	Strong encryption, RBAC, VAPT remediation.	Centralized Incident Tracker, DPIA .
Gaps	Inconsistent severity classification, Manual logs.	Reporting timelines, Cross-border framework.
Risk Level	Medium	Medium-Low

Maturity Score

Overall Score: 3.4 / 5.0

- People: 3/5
- Process: 3.5/5
- Technology: 4/5
- Compliance: 3/5

